

CEH v13 Practice Questions – Module 14: Hacking Web Applications

1. Which of the following is a common web application vulnerability?

- A. SYN flood
- B. Cross-Site Scripting (XSS)
- C. Smurf attack
- D. MAC flooding

Answer: B

2. What is the purpose of input validation in web applications?

- A. To increase response time
- B. To prevent malicious input from being processed
- C. To encrypt traffic
- D. To block file downloads

Answer: B

3. Which tool is commonly used to test web applications for vulnerabilities?

- A. Burp Suite
- B. Aircrack-ng
- C. Nmap
- D. Wireshark

Answer: A

4. What type of vulnerability allows an attacker to execute scripts in a victim's browser?

- A. SQL Injection
- B. XSS
- C. Command Injection
- D. SSRF

Answer: B

5. What is the result of a successful Cross-Site Request Forgery (CSRF) attack?

- A. Theft of data from the server
- B. Execution of unauthorized actions on behalf of a user
- C. Crashing the server application
- D. Injecting malware into memory

Answer: B

6. Which HTTP header can help mitigate XSS attacks?

- A. X-Frame-Options
- B. X-Content-Type-Options
- C. Content-Security-Policy
- D. Server

Answer: C

7. What is the primary danger of SQL Injection in a web application?

- A. Resource exhaustion
- B. Privilege escalation
- C. Unauthorized access to database contents
- D. Cookie manipulation

Answer: C

8. What does session fixation allow an attacker to do?

- A. Hijack a session by setting a predefined session ID
- B. Block a session from starting
- C. Increase session timeout
- D. Disable cookies

Answer: A

9. Which attack vector involves inserting malicious SQL code into form fields?

- A. XSS
- B. LFI
- C. CSRF
- D. SQL Injection

Answer: D

10. Which web vulnerability exploits insecure file inclusion methods?

- A. RFI
- B. XSS
- C. CSRF
- D. DNS Spoofing

Answer: A

11. Which OWASP category includes issues like SQL Injection and XSS?

- A. Broken Access Control
- B. Security Misconfiguration
- C. Injection
- D. Broken Authentication

Answer: C

12. Which of the following can prevent SQL Injection?

- A. Disabling cookies
- B. Parameterized queries
- C. Increasing firewall logs
- D. Adding more database indexes

Answer: B

13. Which component of Burp Suite allows intercepting and modifying HTTP requests?

- A. Repeater
- B. Intruder
- C. Scanner
- D. Proxy

Answer: D

14. What is the purpose of web application firewalls (WAF)?

- A. Prevent unauthorized network access
- B. Detect and block web-based attacks
- C. Encrypt HTTPS traffic
- D. Log wireless activity

Answer: B

15. Which file might contain sensitive application credentials if not secured properly?

- A. favicon.ico
- B. .env
- C. sitemap.xml
- D. robots.txt

Answer: B

16. What is Clickjacking?

- A. Altering links to download malware
- B. Tricking users into clicking invisible elements
- C. Hijacking user sessions
- D. Tracking user behavior through ads

Answer: B

17. Which framework helps identify the top web application risks?

- A. MITRE ATT&CK
- B. OWASP
- C. PCI DSS
- D. NIST

Answer: B

18. What can an attacker accomplish with a successful LFI attack?

- A. Deface a website
- B. Access files on the server
- C. Scan ports
- D. Capture network packets

Answer: B

19. What is a common indicator of insecure authentication in web applications?

- A. Login via HTTPS
- B. Password stored in cookies

- C. CAPTCHA protection
- D. Rate limiting login attempts

Answer: B

20. How can content security policy (CSP) enhance application security?

- A. By preventing cross-origin access to resources
- B. By encrypting cookies
- C. By hashing passwords
- D. By improving compression

Answer: A

21. What does the SameSite cookie attribute help prevent?

- A. Clickjacking
- B. CSRF attacks
- C. SQL Injection
- D. Brute-force login attempts

Answer: B

22. Which tool can automatically scan web apps for vulnerabilities?

- A. ZAP
- B. John the Ripper
- C. Ettercap
- D. Aircrack-ng

Answer: A

23. What does a 500 Internal Server Error indicate?

- A. File not found
- B. Permission denied
- C. Server misconfiguration or failure
- D. Authentication required

Answer: C

24. What is the primary goal of web application pentesting?

- A. Take down the web server
- B. Validate SSL certificates
- C. Identify and exploit vulnerabilities
- D. Improve site aesthetics

Answer: C

25. Which technique allows a hacker to impersonate a trusted user via a forged session?

- A. Broken Authentication
- B. XSS
- C. CSRF
- D. Session Hijacking

Answer: D